보고서 엔진

진단 결과 JSON → 경영진용·실무진용 보고서 자동 생성

발표자 : 송예린

01 LLM 환각 차단

LLM 단독

- 과징금 금액을 지어냄
- 없는 조문·사례 인용
- 무관한 사례 연결
- 빠뜨린 취약점 발생

보고서 엔진

- 금액은 LLM에 안 넘김
- ID로만 참조 → 코드 검증
- 후보 안에서만 사례 선택
- 빠진 항목은 코드가 보완

02 판정은 코드로

사례 지식베이스



보도자료 15건 → 사례 카드

4단계 등급으로 검색

과징금 노출



법정 상한 3%, 감경 40%·30%

유사 처분액 분포

조치 우선순위



심각도 × 개인정보 자산

× 사례 근거 점수

판정은 코드, 문장은 AI, 숫자·조문·조치 방법은 원본 데이터에서 가져옵니다.

03 기술 스택

구분	사용 기술	설정·특징	역할	코드 위치
문장 생성 LLM	OpenAI GPT-4o	temperature 0.2, JSON 모드, 진단당 1회	보고서 문장 작성	engine.py call_llm()
임베딩·검색	text-embedding-3-small + ChromaDB	코사인 유사도 + 메타데이터 필터	유사 처분 사례 검색	case_kb.py
템플릿	Python 3.12 + Jinja2	경영진용·실무진용 템플릿 2개	같은 데이터로 HTML 조립	templates/*.j2
PDF 렌더링	WeasyPrint (+ Pango)	HTML·CSS → PDF, Pretendard 임베드	PDF 2종 출력	engine.py render()
데이터 변환	openpyxl	드롭다운 값·필수값·중복 검사	사례 시트 → JSON	convert_cases.py
금액 계산	Python (규칙 기반)	개정 개인정보 보호법 기준 상수	과징금 노출·우선순위	exposure.py

✓ LLM은 설정만 바꾸면 Claude로 교체 가능 (호출 코드는 call_llm() 하나)

04 프롬프트 설계

역할 분리	판정은 코드가 끝내고 LLM은 문장만 작성 (규칙 16개)
대조 예시	나쁨/좋음 예시 문장으로 기대 수준 제시 (Few-shot)
JSON 출력	출력 스키마 고정 + JSON 모드, temperature 0.2
후보 주입	검색된 사례 후보만 넣고 그 안에서만 인용 (RAG)
금액 제외	원화 금액은 아예 넘기지 않고 ID로만 참조하게 함

05 데이터 구축

사례 카드화

개인정보위 처분 보도자료 15건 →
엑셀 시트에 사례 카드 30장 정리

검사·변환

convert_cases.py가 필수값·형식·
중복 검사 후 cases.json 생성

벡터 DB 적재

사례 1장 = 문서 1개로 임베딩
태그·ISMS-P는 메타데이터 필터

항목 카탈로그

KISA 2026 상세가이드 웹 21개 항목
판단 기준·조치 방법 원문 → JSON

06 보고서 생성 흐름

STEP 01

코드가 판정

module3 JSON을 받아 통계·위험 수준·유사 사례·과징금 노출액을 코드로 계산합니다.

STEP 02

LLM 1회

판정이 끝난 사실만 넘겨 보고서 문장만 쓰게 합니다. 금액은 넘기지 않습니다.

STEP 03

검증

LLM이 쓴 취약점·법령·사례 ID를 실제 데이터와 대조해 없는 ID는 지웁니다.

STEP 04

PDF 2종 생성

같은 데이터로 경영진용 슬라이드와 실무진용 상세 보고서를 만듭니다.

07 검증 코드

engine.py · validate() — LLM 출력 검증, 실제 코드 발췌

① 실제 데이터에 있는 ID만 남기고 나머지는 경고와 함께 제거

```
400 def keep(ids, valid, what, where):
401     good = [i for i in ids or [] if i in valid]
402     for bad in set(ids or []) - set(good):
403         warnings.append(f"{where}: 존재하지 않는 {what} '{bad}' 제거")
404     return good
```

⋮

② 법령은 실제 매핑만, 사례는 그 위험의 검색 후보(참고 등급 제외) 안에서만

```
413     r["law_codes"] = keep(r.get("law_codes"), facts["laws"], "law_code", where)
414     allowed = {h["case_id"]: h["match_level"] for fid in r["finding_ids"]
415                for h in facts["case_candidates"].get(fid, [])}
416     allowed = {c: lv for c, lv in allowed.items() if lv in STRONG_LEVELS}
417     r["case_ids"] = keep(r.get("case_ids"), allowed, "case_id(이 위험의 인용 가능 후보가 아님)",
where)[:2]
```

⋮

③ 문장에 원화 금액이 섞이면 경고 (금액은 템플릿이 원본에서 채움)

```
446 money = re.compile(r"\d[\d,.]*\s*(억|천만|백만|만)?\s*원")
447 texts = [("headline", llm.get("headline", "")), ("summary", llm.get("summary", ""))]
448 texts += [(f"top_risks[{i}]", r.get("impact", "") + " " + r.get("title", "")) for i, r
in enumerate(risks)]
449 texts += [(f"decisions[{i}]", d) for i, d in enumerate(llm.get("decisions", []))]
450 for where, t in texts:
451     if money.search(t or ""):
452         warnings.append(f"{where}: 문장에 금액이 들어 있음 → '{money.search(t).group(0)}' (금액
은 템플릿이 채워야 함)")
```

engine.py validate()

LLM 출력을 그대로 쓰지 않고, 코드가 실제 데이터와 대조한 뒤에만 보고서에 넣습니다.
걸린 항목은 run_log.json에 경고로 남습니다.

검사하는 것

- 없는 취약점·조문·사례 ID 제거
- 후보 밖·참고 등급 사례 인용 차단
- 로드맵 누락 취약점 자동 추가
- 문장 속 원화 금액 경고

08 경영진용 보고서



입력

module3 출력 JSON (SCAN-2026-002, 취약 1건)

구성

16:9 슬라이드 7장 · 결론·위험·과징금·로드맵

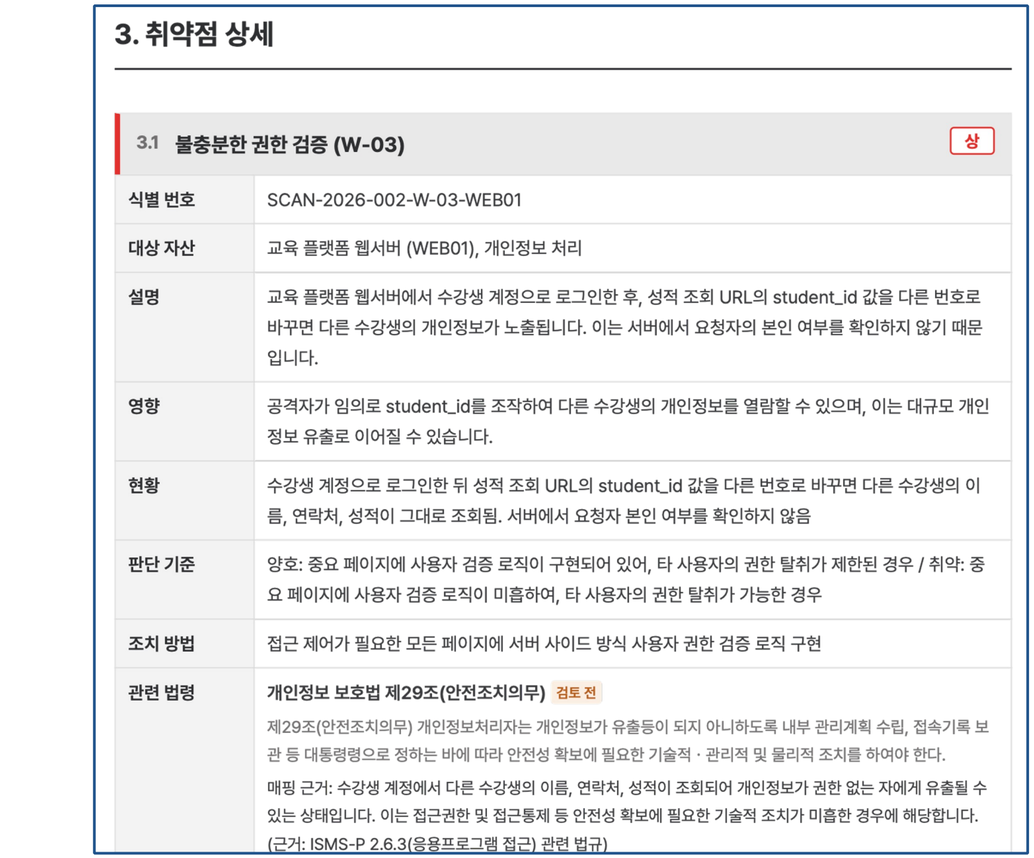
이 진단에서 나온 결과

→ 전체 위험 수준 '심각'

→ 법정 상한 1억 5,000만 원

→ 유사 처분 사례 4건 인용

09 실무진용 보고서



3. 취약점 상세

3.1 불충분한 권한 검증 (W-03) 상

식별 번호	SCAN-2026-002-W-03-WEB01
대상 자산	교육 플랫폼 웹서버 (WEB01), 개인정보 처리
설명	교육 플랫폼 웹서버에서 수강생 계정으로 로그인한 후, 성적 조회 URL의 student_id 값을 다른 번호로 바꾸면 다른 수강생의 개인정보가 노출됩니다. 이는 서버에서 요청자의 본인 여부를 확인하지 않기 때문입니다.
영향	공격자가 임의로 student_id를 조작하여 다른 수강생의 개인정보를 열람할 수 있으며, 이는 대규모 개인정보 유출로 이어질 수 있습니다.
현황	수강생 계정으로 로그인한 뒤 성적 조회 URL의 student_id 값을 다른 번호로 바꾸면 다른 수강생의 이름, 연락처, 성적이 그대로 조회됨. 서버에서 요청자 본인 여부를 확인하지 않음
판단 기준	양호: 중요 페이지에 사용자 검증 로직이 구현되어 있어, 타 사용자의 권한 탈취가 제한된 경우 / 취약: 중요 페이지에 사용자 검증 로직이 미흡하여, 타 사용자의 권한 탈취가 가능한 경우
조치 방법	접근 제어가 필요한 모든 페이지에 서버 사이드 방식 사용자 권한 검증 로직 구현
관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 수강생 계정에서 다른 수강생의 이름, 연락처, 성적이 조회되어 개인정보가 권한 없는 자에게 유출될 수 있는 상태입니다. 이는 접근권한 및 접근통제 등 안전성 확보에 필요한 기술적 조치가 미흡한 경우에 해당합니다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규)

구성

A4 상세 보고서 7쪽: 진단 개요, 결과 요약, 취약점 상세, 부록.
판단 기준과 조치 방법은 KISA 가이드 원문을, 관련 법령은 조문 원문을 그대로 싣습니다.

취약점 상세에 담는 것

- 현황·판단 기준·조치 방법
- 관련 법령 원문과 매핑 근거
- 미검토 매핑은 '검토 전' 표시
- 부록: 과징금 산정·우선순위

10 실무진용 부록

4.2 보고서 생성 방식

결과 판정(위험도, 취약·양호, 전체 위험 수준)은 진단 데이터와 정해진 규칙으로 산출했습니다. 설명과 영향 문장은 AI가 작성했으며, 판단 기준과 조치 방법은 항목 카탈로그에서, 법령 조문은 기준 문서 원문에서 그대로 가져왔습니다.

유사 사례는 개인정보보호위원회 처분 보도자료 원문으로 확인한 사례 카드에서 검색했고, 과징금 노출액과 조치 우선순위는 아래 기준으로 코드가 계산했습니다. 금액은 AI를 거치지 않았습니다.

4.3 과징금 노출 산정

항목	값	근거·설명
법정 상한	1억 5,000만 원	전체 매출액에서 위반과 무관한 매출을 뺀 금액의 3%. 개인정보 보호법 제64조의2(과징금의 부과), 2026-09-11 시행 개정법
10% 특례 시나리오	5억 원	고의·중과실로 3년 내 같은 유형 반복 위반: 해당 없음 (고객사 프로필의 3년 내 위반 이력 기준. 고의·중과실 여부는 도구가 판단하지 않음) 고의·중과실로 피해 1천만 명 이상: 해당 없음 (정보주체 120,000명 → 1천만 명 기준 미달) 시정명령 불이행으로 유출: 해당 없음 (고객사 프로필의 시정명령 미이행 여부 기준)
투자 감경	최대 40%	보호 투자·보호체계 운영·추가 안전조치를 고려해 기준금액의 최대 40% 감경. 위반 전 3개 사업연도 노력을 보며 고의·중과실 위반은 제외. 상한 기준 예시 9,000만 원
ISMS-P 인증 감경	최대 30%	현재 미인증. ISMS-P 인증에 따른 감경 상한은 최대 30%(개정 전 50%). 중요 개인정보처리자 대상 인증 의무화는 2027-07-01 시행 예정

숫자의 출처를 남긴다

보고서의 금액과 판정이 어디서 나왔는지 부록에서 추적할 수 있게 했습니다.
화면은 SCAN-2026-002의 4.2 생성 방식과 4.3 과징금 노출 산정입니다.

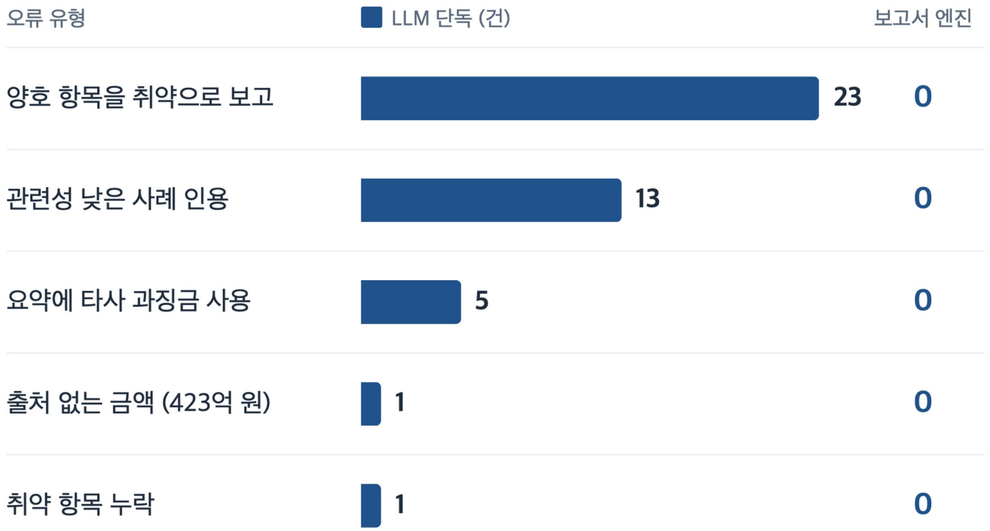
부록 구성

- 4.1 기준 문서 원본 목록
- 4.2 보고서 생성 방식
- 4.3 과징금 노출 산정
- 4.4~4.5 우선순위·가정·제외

11 비교 실험

보고서 15건에서 나온 오류 (자동 채점)

GPT-4o · temperature 0.2 · 같은 출력 형식 · 진단 3건 × 5회



보고서 엔진은 검증(validate) 전 출력에서도 모든 유형 0건.
오류가 하나라도 있는 보고서: LLM 단독 15/15, 보고서 엔진 0/15.

실험 설계

GPT-4o·temperature 0.2·같은 출력 형식으로 진단 3건을 5회씩 생성해 자동 채점했습니다.
LLM 단독은 진단 JSON·매출·사례 과징금을 그대로 받았습니다.

✓ 오류 있는 보고서	15/15 → 0/15
✓ 양호 항목 오보	23건 → 0건
✓ 관련성 낮은 사례	13건 → 0건
✓ 요약 속 과징금	5건 → 0건

12 정량 결과

0 건

엔진 오류

엔진 보고서 15건 오류 0건
(LLM 단독은 15건 모두 오류)

8/8

오류 탐지

가짜 ID·금액 등 8종 주입 시험
8종 모두 탐지·제거·경고

9.5 초

보고서 1건

LLM 평균 7.9초 +
사례 검색·PDF 2종 1.6초

43%

입력 토큰 절감

LLM 단독 8,580 → 엔진 4,923
필요한 사실만 골라 전달

✓ 진단 3건 × 5회 실측 (GPT-4o) · 취약점 8건 중 7건에 동일 결함 사례 매칭

13 설계 상세 Q&A

예상 질문 10개 — 답과 근거(실제 코드·실제 출력)
를 함께 정리했습니다

Q1

환각 ID 차단

engine.py · validate() — LLM이 쓴 ID를 원본과 대조

① keep(): 원본 데이터(facts)에 있는 ID만 남기고 나머지는 경고와 함께 제거

engine.py : 400–404

```python
def keep(ids, valid, what, where):
    good = [i for i in ids or [] if i in valid]
    for bad in set(ids or []) - set(good):
        warnings.append(f"{where}: 존재하지 않는 {what} '{bad}' 제거")
    return good
```

② 위험마다 취약점 → 법령 순서로 검사, 유효한 취약점이 없으면 위험 항목 자체를 삭제

engine.py : 406–413

```python
risks, used_cases = [], set()
for i, r in enumerate(llm.get("top_risks", [])[:3]):
    where = f"top_risks[{i}]"
    r["finding_ids"] = keep(r.get("finding_ids"), vuln_ids, "finding_id", where)
    if not r["finding_ids"]:
        warnings.append(f"{where}: 유효한 취약점이 없어 위험 항목 제거")
        continue
    r["law_codes"] = keep(r.get("law_codes"), facts["laws"], "law_code", where)
```

③ 가짜 ID를 넣은 시험의 실제 경고 (run_log.json)

```
top_risks[0]: 존재하지 않는 finding_id 'SCAN-2026-002-FAKE-99' 제거
top_risks[0]: 존재하지 않는 law_code 'PIPA-999' 제거
top_risks[0]: 존재하지 않는 case_id(이 위험의 인용 가능 후보가 아님) 'PIPC-2099-001' 제거
top_risks[1]: 유효한 취약점이 없어 위험 항목 제거
```

질문

LLM이 문장을 쓰다가 없는 법령 ID나 취약점 ID를 지어내면 어떻게 막나요?

답변 요점

→ 원본 ID 목록과 대조 (keep)

→ 없는 ID는 제거 + 경고 기록

→ 근거 없는 위험은 통째 삭제

→ 주입 시험 8종 모두 탐지

Q2

4단계 사례 검색

case_kb.py · search_cases() — 메타데이터 필터 + 단계적 폴백

① 적재: 목록형 태그를 True 플래그로 펼쳐 Chroma 메타데이터에 저장

case_kb.py : 88–96

```python
for v in card.get("team_vuln", []):
    if v in VULN_SLUG:
        m[f"vuln_{VULN_SLUG[v]}"] = True
for t in card.get("attack_tags", []):
    m[f"tag_{slug(t)}"] = True
for i in card.get("isms_p_ids", []):
    m[f"isms_{slug(i)}"] = True
for c in card.get("violated_codes", []):
    m[f"code_{slug(c)}"] = True
```

② 검색: 필터를 바꿔 가며 위 등급부터 채우고, 모자라면 다음 등급으로

case_kb.py : 144–155

```python
isms_f = _flag_filter([f"isms_{slug(i)}" for i in isms_ids])
vuln_f = {f"vuln_{VULN_SLUG[team_vuln]}": True} if team_vuln in VULN_SLUG else None

# 위에서부터 채우고, 모자라면 다음 등급으로 내려간다
tiers = []
if isms_f and vuln_f:
    tiers.append(("동일 결함 사례", {"$and": [isms_f, vuln_f]}))   # ISMS-P 기준 + 팀 취약점 둘 다 일치
if vuln_f:
    tiers.append(("같은 취약점 유형", vuln_f))                      # 팀 취약점만 일치 (같은 결함 종류)
if isms_f:
    tiers.append(("관련 통제 사례", isms_f))                        # ISMS-P 기준만 일치 (같은 통제 영역)
tiers.append(("참고 사례", None))                                   # 필터 없이 유사도만
```

③ 같은 보도자료(source_file)는 한 건만 → 쌍둥이 카드가 결과를 독차지하지 않게

case_kb.py : 165–172

```python
for cid, doc, meta, dist in zip(res["ids"][0], res["documents"][0],
                                res["metadatas"][0], res["distances"][0]):
    src = meta.get("source_file") or cid
    if cid in seen_ids or src in seen_sources:   # 보도자료 하나당 한 건만
        continue
    seen_ids.add(cid)
    seen_sources.add(src)
    results.append({"case_id": cid, "match_level": level, "distance": round(dist, 4),
```

질문

유사 사례를 유사도만으로 찾으면 엉뚱한 사례가 나오지 않나요?

4단계 등급은 어떻게 구현했나요?

답변 요점

→ 동일 결함: ISMS-P AND 취약점

→ 같은 유형: 취약점 태그 일치

→ 관련 통제: ISMS-P만 일치

→ 참고: 유사도만 → 인용 금지

Q3

상한을 넘는 사례 금액

exposure.py · compute() — 중앙값이 고객사 상한을 넘으면 경고 생성

① 사례 중앙값 > 고객사 법정 상한이면 median_exceeds_client_cap + warning 생성

exposure.py : 210–217

```
210 dist = evidence["fine_distribution"]
211 if dist:
212     dist["over_client_cap_count"] = sum(1 for c in dist["case_ids"]
213                                         if evidence_fine(evidence, c) > cap["cap_krw"])
214     dist["median_exceeds_client_cap"] = dist["median_krw"] > cap["cap_krw"]
215     if dist["median_exceeds_client_cap"]:
216         dist["warning"] = ("유사 사례 중앙값이 이 고객사의 법정 상한보다 큼. 사례 기업이 더 커서 생긴 차이이므로 "
217                            "사례 금액을 고객사 예상 과징금처럼 쓰면 안 됨 (상한을 넘는 과징금은 불가능)")
```

② 템플릿: 경고가 있을 때만 각주·부록에 출력

exec.html.j2 : 302–302

```
302 {% if d and d.median_exceeds_client_cap %}<br>유사 사례 금액이 상한보다 큰 것은 사례 기업의 매출 규모가 더 크기 때문이며, 같은 결함이 실제로 처분받은 규모를 보여주기 위한 참고값입니다.{% endif %}
```

tech.html.j2 : 246–246

```
246 <td>{% if d %}최소 {{ d.min_krw|krw }}, 중앙값 {{ d.median_krw|krw }}, 최대 {{ d.max_krw|krw }}. {% endif %}{{ ex.case_evidence.note }}{% if d and d.warning %}<br>{{ d.warning }}{% endif %}</td></tr>
```

③ 실제 출력: SCAN-2026-003 실무진용 부록 4.3

항목	값	근거·설명
유사 처분 사례 과징금	6건	최소 329만 원, 중앙값 20억 3,550만 원, 최대 151억 4,196만 원. 참고 사례를 뺀 등급(동일 결함·같은 유형·관련 통제)의 처분 사례 중 과징금이 있는 것만 집계. 사례 기업과 고객사의 매출 규모가 달라 예상 부과액이 아니라 '유사 사례에서 실제로 나온 금액'임 유사 사례 중앙값이 이 고객사의 법정 상한보다 큼. 사례 기업이 더 커서 생긴 차이이므로 사례 금액을 고객사 예상 과징금처럼 쓰면 안 됨 (상한을 넘는 과징금은 불가능)

질문

유사 사례 과징금 중앙값이 고객사 법정 상한보다 훨씬 크면 보고서 신뢰도가 떨어지지 않나요?

답변 요점

- 중앙값 > 상한이면 경고 생성
- 경영진용 각주에 자동 표시
- 실무진용 부록 4.3에 경고문
- 상한 초과 사례 수도 집계

Q4

금액은 템플릿이

engine.py · facts_for_llm() / 템플릿 — 금액은 LLM을 거치지 않는다

① LLM 입력에서 금액을 뺀다 (매출, 사례 과징금, 노출액)

engine.py : 262–266

```
def facts_for_llm(facts):
    """LLM에 넘길 최소한의 사실만 추린다. 판례 금액은 일부러 빼서 LLM이 숫자를 옮겨 적다 틀릴 일을 없앤다."""
    # 로고 경로, 안내 문구, 메모는 문장 생성에 필요 없으니 빼고 넘긴다
    ctx = {k: v for k, v in facts["context"].items()
           if k not in ("logo", "disclaimer", "exposure_profile") and not k.startswith("_")}
# 매출 등 금액은 LLM에 안 넘김
```

engine.py : 289–290

```
def exposure_hints(ex):
    """노출액 결과에서 문장에 필요한 사실만. 원화 금액은 일부러 뺀다 (금액은 템플릿이 채운다)."""
```

② enrich(): LLM이 고른 ID에 원본 법령·사례 데이터를 다시 붙인다

engine.py : 476–480

```
r["laws"] = [{
    **facts["laws"][c],
    "unreviewed": any(not l.get("reviewed") for f in fs for l in f.get("violated_laws", [])
if l["law_code"] == c),
} for c in r["law_codes"]]
r["cases"] = [{**facts["cases"][c], "level": case_level(facts, c, r["finding_ids"])} for c in
r["case_ids"]]
```

③ 템플릿이 원본 금액을 직접 출력하고, krw 필터가 표기만 바꾼다

exec.html.j2 : 262–262

```
<span class="m-num must">{{ cap.cap_krw|krw }}</span>
```

engine.py : 514–523

```
def krw(n):
    """원화를 보고서 표기로: 150000000 → '1억 5,000만 원'. 만 원 아래 단위가 있으면 원 단위 그대로."""
    if n is None:
        return "–"
    n = int(n)
    if n < 10_000 or n % 10_000:
        return f"{n:,}원"
    eok, man = divmod(n // 10_000, 10_000)
    parts = ([f"{eok:,}억"] if eok else []) + ([f"{man:,}만"] if man else [])
    return " ".join(parts) + " 원"
```

질문

LLM이 금액을 문장에 못 쓰게 했는데, 최종 PDF의 원화 금액은 어떻게 들어가나요?

답변 요점

- LLM 입력에서 금액 제외
- LLM은 ID와 문장만 출력
- enrich()가 원본 데이터 결합
- 템플릿이 금액 직접 출력

Q5

모르는 항목 ID

engine.py · resolve_catalog() — 모르는 항목 ID가 와도 멈추지 않는다

① 카탈로그에 없으면 이름 일치 → ID 앞부분 일치 순으로 연결, 실패해도 예외 없이 메모만 남김

engine.py : 94–117

```
 94 def resolve_catalog(scan, catalog):
 95     """카탈로그에 없는 item_id는 (1) 점검 항목 이름 → (2) ID 앞부분 순서로 KISA 항목에 연결한다.
 96   예: W-03 '불충분한 권한 검증' → IN (이름), IL-COMMENT-01 → IL (ID 앞부분)
 97   연결된 항목의 이름은 f["team_vuln"]에 남겨서 사례 검색(case_kb)도 같은 기준을 쓰게 한다."""
 98     key = lambda t: re.sub(r"\s+|\(.*?\)", "", t or "")
 99     by_title = {key(v.get("title")): k for k, v in catalog.items() if isinstance(v, dict) and
v.get("title")}
100     notes = []
101     for f in scan.get("findings", []):
102         iid = f.get("item_id")
103         if iid not in catalog:
104             hit, how = by_title.get(key(f.get("title"))), "이름 일치"
105             if not hit:
106                 prefix = (iid or "").split("-")[0]
107                 if isinstance(catalog.get(prefix), dict):
108                     hit, how = prefix, "ID 앞부분 일치"
109             if hit:
110                 catalog[iid] = catalog[hit]
111                 notes.append(f"{iid} '{f.get('title')}' → 카탈로그 {hit} 항목 사용 ({how})")
112             else:
113                 notes.append(f"{iid} '{f.get('title')}' → 카탈로그에 없음 (실무진용 판단 기준·조치 방법 칸이 비어
나옴)")
114         entry = catalog.get(iid)
115         if isinstance(entry, dict) and entry.get("title"):
116             f["team_vuln"] = entry["title"]
117     return notes
```

② 실제 시험: 진단 JSON의 항목을 W-99 '신규 스캐너 점검 항목'으로 바꿔 실행

```
[카탈로그] W-99 '신규 스캐너 점검 항목' → 카탈로그에 없음 (실무진용 판단 기준·조치 방법 칸이 비어 나옴)
[facts] 취약 1건 / 전체 2개, 위험 수준 심각
[render] .../exec_report.pdf
[render] .../tech_report.pdf      → exit 0, PDF 2종 정상 생성
```

질문

스캐너가 업데이트되어 카탈로그에 없는 새 항목 ID(예: W-99)를 넘기면 엔진이 멈추나요?

답변 요점

- 이름 일치로 1차 연결
- ID 앞부분으로 2차 연결
- 없으면 빈칸 + 콘솔 안내
- W-99 시험: PDF 정상 생성

Q6

우선순위 점수

exposure.py · priority() — 우선순위 점수 공식

① 가중치: 심각도 · 사례 근거 등급 · 개인정보 자산

exposure.py : 48–50

```
48 SEV_W = {"상": 3, "중": 2, "하": 1}
49 EVIDENCE_W = {"동일 결함 사례": 1.0, "같은 취약점 유형": 0.7, "관련 통제 사례": 0.5, "참고 사례": 0.3, None:
0.2}
50 PII_W = {True: 1.0, False: 0.3}
```

② 심각도가 먼저, 사례 근거는 최대 1.5배까지만 → '상'은 근거가 약해도 '중'보다 뒤로 가지 않음

exposure.py : 183–191

```
183 def priority(active, per_finding):
184     rows = []
185     for f in active:
186         hits = per_finding.get(f["finding_id"], [])
187         best = hits[0]["match_level"] if hits else None
188         pii = bool((f.get("asset") or {}).get("handles_personal_data", False))
189         # 심각도가 먼저, 사례 근거는 최대 1.5배까지만 올린다 → '상'은 근거가 약해도 '중'보다 뒤로 가지 않는다
190         score = SEV_W.get(f.get("severity"), 1) * PII_W[pii] * (1 + 0.5 * EVIDENCE_W[best])
191         rows.append({"finding_id": f["finding_id"], "title": f.get("title"), "severity":
f.get("severity"),
```

③ 실제 출력: SCAN-2026-003 실무진용 부록 4.4 3×1.0×1.5 = 4.5 / 2×1.0×1.5 = 3.0

4.4 조치 우선순위

순위	점검 항목	위험도	사례 근거	점수	여기까지 조치 시
1	주석 내 정보 누출	상	동일 결함	4.5	리스크 60.0% 감소
2	에러페이지 정보 노출	중	동일 결함	3.0	리스크 100.0% 감소

점수 = 심각도(상3·중2·하1) × 개인정보 자산(예 1.0·아니오 0.3) × (1 + 0.5 × 사례 근거(동일 결함 1.0·같은 유형 0.7·관련 통제 0.5·참고 0.3·없음 0.2)). 점수는 조치 순서를 정하기 위한 상대값이며 금액이 아닙니다.

질문

실무진용 부록 4.4에서 '주석 내 정보 누출'은 4.5점, '에러페이지 정보 노출'은 3.0점입니다. 어떻게 계산되나요?

답변 요점

→ 심각도 상3·중2·하1

→ 개인정보 자산 1.0, 아니면 0.3

→ × (1 + 0.5 × 사례 근거)

→ 3×1×1.5=4.5 / 2×1×1.5=3.0

Q7

노출액 제외

exposure.py · classify() — 법 조항이 없으면 노출액에서 제외

① 양호 → 제외, 관련 법 조항 없음 → ISMS-P 심사 리스크로만, 개인정보 미처리 자산 → 제외

exposure.py : 118–134

```python
def classify(findings, profile):
    """계산 대상 취약점과 제외 항목을 나눈다."""
    public = bool(profile.get("is_public_institution"))
    active, excluded, by_code = [], [], {}
    for f in findings:
        fid = f["finding_id"]
        if f.get("status") != "취약":
            excluded.append({"finding_id": fid, "reason": f"상태가 '{f.get('status')}'라 노출액 계산에서 제외"})
            continue
        active.append(f)
        pii = (f.get("asset") or {}).get("handles_personal_data", False)
        if not f.get("violated_laws"):
            excluded.append({"finding_id": fid, "reason": "관련 법 조항이 없어 법적 노출액에서 제외 (ISMS-P 심사 리스크로만 다룸)"})
            continue
        if not pii:
            excluded.append({"finding_id": fid, "reason": "개인정보를 처리하지 않는 자산이라 개인정보보호법 노출액에서 제외"})
            continue
```

② 실제 출력: SCAN-2026-003 실무진용 부록 4.5

4.5 산정 가정과 제외 항목

- 고객사 프로필(매출·정보주체 수 등)은 모의 교육 플랫폼 가정값
- 법정 상한은 최대치이며 예상 부과액이 아님
- 같은 조항에 걸린 취약점이 여러 개여도 법정 상한은 한 번만 적용
- 유사 사례 금액은 대부분 개정법 시행(2026-09-11) 이전 구법 기준 처분
- 투자 감경 예시값은 법정 상한에 최대 감경률을 적용한 것으로, 실제 감경은 기준금액에 적용됨
- 우선순위 점수는 조치 순서를 정하기 위한 상대 점수이며 금액이 아님

제외 항목	사유
중요 정보 마스킹 미흡	상태가 '양호'라 노출액 계산에서 제외
에러페이지 정보 노출	관련 법 조항이 없어 법적 노출액에서 제외 (ISMS-P 심사 리스크로만 다룸)

질문

'에러페이지 정보 노출'은 위험도가 '중'인데 왜 과징금 계산에서 빠졌나요?

답변 요점

→ 관련 법 조항 매핑 없음

→ → ISMS-P 심사 리스크로만

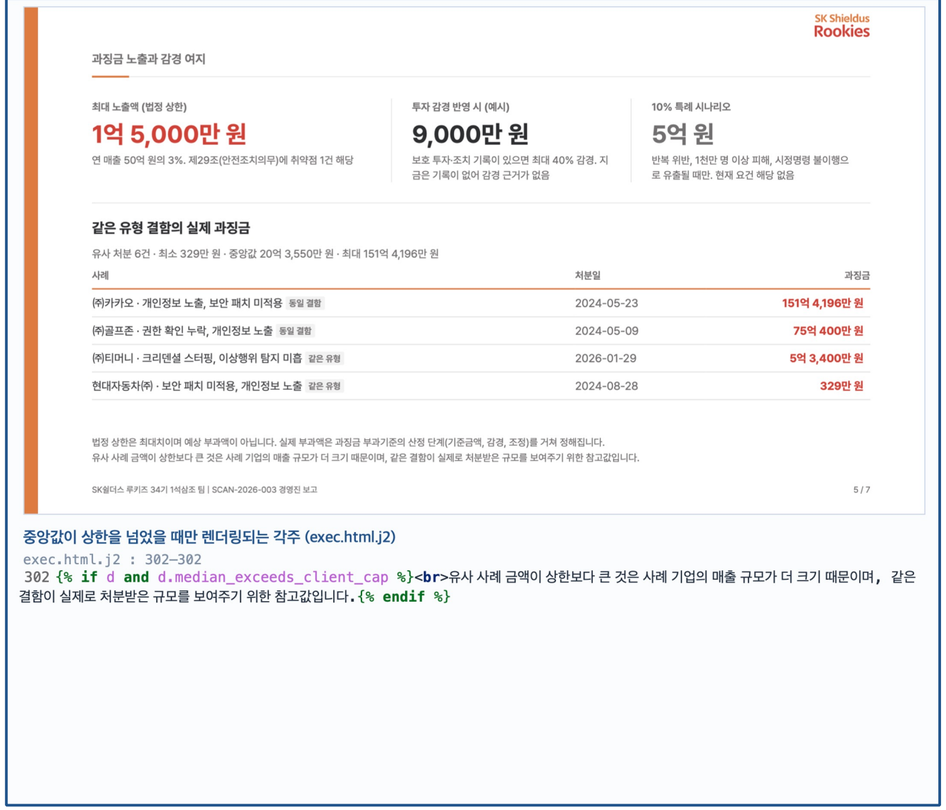
→ 양호·비개인정보 자산도 제외

→ 제외 사유는 부록 4.5에 공개

Q8

상한 vs 사례 중앙값

경영진용 보고서 5쪽 (SCAN-2026-003) — 상한 1억 5,000만 원 vs 사례 중앙값 20억 3,550만 원



SK Shieldus Rookies

과징금 노출과 감경 여지

최대 노출액 (법정 상한)	투자 감경 반영 시 (예시)	10% 특례 시나리오
1억 5,000만 원	**9,000만 원**	**5억 원**
연 매출 50억 원의 3%. 제29조(안전조치의무)에 취약점 1건 해당	보호 투자·조치 기록이 있으면 최대 40% 감경. 지금은 기록이 없어 감경 근거가 없음	반복 위반, 1천만 명 이상 피해, 시정명령 불이행으로 유출될 때만. 현재 요건 해당 없음

같은 유형 결함의 실제 과징금

유사 처분 6건 · 최소 329만 원 · 중앙값 20억 3,550만 원 · 최대 151억 4,196만 원

사례	처분일	과징금
(주)카카오 · 개인정보 노출, 보안 패치 미적용 동일 결함	2024-05-23	151억 4,196만 원
(주)골프존 · 권한 확인 누락, 개인정보 노출 동일 결함	2024-05-09	75억 400만 원
(주)티머니 · 크리덴셜 스터핑, 이상행위 탐지 미흡 같은 유형	2026-01-29	5억 3,400만 원
현대자동차(주) · 보안 패치 미적용, 개인정보 노출 같은 유형	2024-08-28	329만 원

법정 상한은 최대치이며 예상 부과액이 아닙니다. 실제 부과액은 과징금 부과기준의 산정 단계(기준금액, 감경, 조정)를 거쳐 정해집니다.
유사 사례 금액이 상한보다 큰 것은 사례 기업의 매출 규모가 더 크기 때문이며, 같은 결함이 실제로 처분받은 규모를 보여주기 위한 참고값입니다.

SK쉴더스 루키즈 34기 1석삼조 팀 | SCAN-2026-003 경영진 보고 5 / 7

중앙값이 상한을 넘었을 때만 렌더링되는 각주 (exec.html.j2)

exec.html.j2 : 302–302

```
302 {% if d and d.median_exceeds_client_cap %}<br>유사 사례 금액이 상한보다 큰 것은 사례 기업의 매출 규모가 더 크기 때문이며, 같은 결함이 실제로 처분받은 규모를 보여주기 위한 참고값입니다.{% endif %}
```

질문

경영진용 5쪽에서 법정 상한은 1억 5,000만 원인데 사례 중앙값은 20억 3,550만 원입니다. 혼란스럽지 않나요?

답변 요점

- 상한은 최대치, 사례는 참고값
- 조건부 각주가 자동 출력
- 사례 금액은 표에만 표시
- LLM 문장에는 금액 0건

Q9

10% 특례 시나리오

exposure.py · legal_cap() — 10% 특례는 '조건이 붙으면' 시나리오

① 특례 요건 3가지를 고객사 프로필로 점검 (고의·중과실 여부는 도구가 판단하지 않음)

exposure.py : 69–80

```
69 subjects = profile.get("data_subjects") or 0
70 conditions = [
71     {"name": "고의·중과실로 3년 내 같은 유형 반복 위반",
72      "possible": bool(profile.get("prior_violation_within_3y")),
73      "why": "고객사 프로필의 3년 내 위반 이력 기준. 고의·중과실 여부는 도구가 판단하지 않음"},
74     {"name": "고의·중과실로 피해 1천만 명 이상",
75      "possible": subjects >= MASS_VICTIMS,
76      "why": f"정보주체 {subjects:,}명 → 1천만 명 기준 {'이상' if subjects >= MASS_VICTIMS else '미달'}"},
77     {"name": "시정명령 불이행으로 유출",
78      "possible": bool(profile.get("corrective_order_pending")),
79      "why": "고객사 프로필의 시정명령 미이행 여부 기준"},
80 ]
```

exposure.py : 87–92

```
87 "special_10pct": {
88     "cap_krw": sp_cap,
89     "possible": any(c["possible"] for c in conditions),
90     "conditions": conditions,
91     "note": "세 요건 중 하나에 해당할 때만 적용. 보고서에는 '이 조건이 붙으면' 시나리오로만 표기",
92 },
```

② 실제 출력: 요건 해당이 없으면 회색 숫자 + '현재 요건 해당 없음'

최대 노출액 (법정 상한)	투자 감경 반영 시 (예시)	10% 특례 시나리오
1억 5,000만 원	**9,000만 원**	**5억 원**
연 매출 50억 원의 3%. 제29조(안전조치의무)에 취약점 1건 해당	보호 투자·조치 기록이 있으면 최대 40% 감경. 지금은 기록이 없어 감경 근거가 없음	반복 위반, 1천만 명 이상 피해, 시정명령 불이행으로 유출될 때만. 현재 요건 해당 없음

질문

요건에 해당하지 않는 '10% 특례 시나리오(5억 원)'를 왜 굳이 보여주나요?

답변 요점

- 요건 3가지를 코드로 점검
- 해당 없으면 회색 + '해당 없음'
- 대응을 잘못했을 때의 상한
- 예상액이 아닌 시나리오

Q10

검토 전 표시

검토 전 표시 (Human-in-the-loop) — 매핑은 module3, 표시와 문장 통제는 보고서 엔진

① 법적 영향 분석 모듈(module3)은 모든 매핑을 reviewed: False로 넘긴다 (builder.py)

builder.py : 85–86

```
85 "mapped_by": "rule",
86 "reviewed": False,
```

② 보고서 엔진: LLM에는 단정 금지 규칙, 템플릿에는 '검토 전' 배지

engine.py : 310–310

```
310 3. reviewed가 false인 법령 매핑은 단정하지 말고 "위반 소지"로 표현한다.
```

tech.html.j2 : 191–191

```
191 {% if l.reviewed %}<span class="review yes">검토 완료</span>{% else %}<span class="review no">검토 전</span>{% endif %}
```

③ 실제 출력: SCAN-2026-003 실무진용 취약점 상세

관련 법령	개인정보 보호법 제29조(안전조치의무) 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 로그인 페이지 주석에 테스트 계정 정보가 노출되어 개인정보 유출 위험이 있으므로 개인정보 보호법 제29조의 안전성 확보 조치 의무에 위배된다. (근거: ISMS-P 2.5.1(사용자 계정 관리), 2.6.3(응용프로그램 접근) 관련 법규) 개인정보의 안전성 확보조치 기준 제5조 제4항, 제5항(접근 권한의 관리) 검토 전 제5조(접근 권한의 관리) ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다. ② 개인정보처리자는 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하여야 한다. ③ 개인정보처리자는 제1항 및 제2

질문

AI가 법령과 인증기준을 자동으로 매핑했는데, 왜 '검토 전' 상태를 따로 두었나요?

답변 요점

- module3가 reviewed: False로 전달
- 보고서에 '검토 전' 배지
- LLM은 '위반 소지'로만 서술
- 검토 전 건수를 결론에 명시